

HOSPITAL BACKUP SYSTEM

Contents

Introduction 2

Hospital Backup System Digital Layer 3

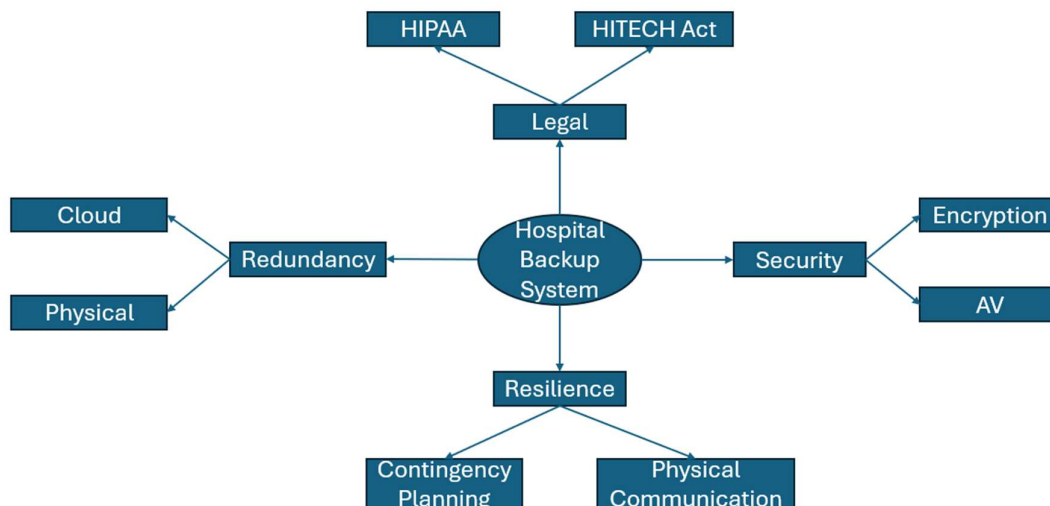
Hospital Backup System Physical Layer 4

Hospital Backup System Trade-offs 5

Introduction

This hospital backup system was designed to provide hospitals with both redundant and resilient systems. It was also made to help hospitals comply with laws like HIPAA and the HITECH Act. This hospital backup system was made because hospitals are critical infrastructure that cannot afford to lose patient data. It is also important because these backup systems can be the difference between life or death for patients within hospitals. This hospital backup system uses pre-existing options for cloud storage and devices however it also provides methods that don't require hospitals to completely trust a third-party. This backup system is also designed to use as least budget as possible while also providing redundancy and resilience for such critical infrastructure.

This hospital backup system cannot promise perfect redundancy, resilience or complete zero-budget. However, this hospital backup system can promise a high level of resilience and redundancy both digitally and physically while keeping spending as low as possible. This hospital backup system will mention some security features that hospitals can use. There is more detail on incident response and more in-depth security features in my security repo. It is important to know that this system will have to be implemented slowly and that hospitals should adapt based on budget and resources.



The spider diagram above shows the key principles built into the foundation of this hospital backup system. It also shows 2 features of the backup system that allow it to comply with the principles. This diagram does not show all features of the backup system. More detail can be found in the sections below.

Hospital Backup System Digital Layer

- This hospital backup system's digital layer focuses on cloud storage, automation, devices and digital security & recovery.
- For cloud storage, hospitals require 2-3 solutions which are private, secure and redundant.
- Hospitals could use options such as Proton Drive, Sync.com or Tresorit
- This is because all 3 options use a zero-knowledge architecture and end-to-end encryption so patient data cannot be seen by the provider
- Proton Drive may be useful for storing contingency plans and recovery codes instead of patient data.
- This is because Proton Drive doesn't have an BAA (Business Associate Agreement) which some hospitals require for compliance.
- Sync.com and Tresorit both provide an BAA so hospitals can use these services for storing and backing up Patient data.
- It is important that these accounts are secured with 16-character passwords, MFA via authentication app or hardware key and encrypted recovery codes stored in multiple locations.
- These 3 options are not the only secure and private cloud providers out there.
- Hospital IT teams may also set up cloud sync, automated scripts for backups, alerts for failures and error-handling.
- This is important as backing up data manually can be time-consuming and is not sustainable for IT teams.
- IT teams should also use methods such as versioning to ensure that if the latest backup has been corrupted or lost then other backups remain.
- For devices, patient data should be stored on medical workstations for staff at the hospitals to access patient data during checkups or other activities.
- These devices should have device encryption enabled, strong account passwords with a password policy of 8 characters minimum, rate limiting and lockout durations.
- IT teams should also enable RBAC and VLAN's to ensure that network traffic is segmented and the blast radius of malware especially ransomware is reduced.
- RBAC is important to ensure that employees do not have access to all patient or hospital data in case of an insider threat or external compromise.
- VLAN's ensure that certain employees or patients cannot access patient data via the network while they are connected.
- Patient data should also be accessible within RBAC limits on medical workstations for doctors, nurses and other medical staff to access when needed.
- For Ransomware recovery, Hospitals should have copies of Windows or operating systems to restore after the ransomware is removed.
- More details on malware removal and recovery processes can be found in the malware handling protocol in my security repo.
- Remember to adapt this layer to your resources and budget.

Hospital Backup System Physical Layer

- This hospital's backup system's physical layer focuses on resilience, contingency planning and communication.
- This physical layer includes paper copies, off-site storage and backup devices.
- For paper copies, hospitals should store the most critical medical knowledge.
- This critical medical knowledge can include CPR, Heimlich Maneuver and Recovery Position
- These paper copies should be stored securely in a folder which is in a safe to prevent both damage and compromise.
- Paper copies are important for hospitals as it allows staff to provide critical medical care without most digital tools.
- For offsite storage, medical staff should store hard drives (SSD/HDD) in a secure location.
- This secure location should be away from the hospital, and the hard drives should be stored in a safe or in a storage unit with a lock.
- These secure locations could be a house with a safe, Bank Safety Deposit Box or off-Site Data Centre
- It is important to note that bank safety deposit box and off-site data centre require larger budgets and have limited access.
- Hard drives should use FDE (Full disk encryption) via VeraCrypt or BitLocker to ensure that an attacker cannot read the data without the correct key.
- Hard drives should also be about 1-2 TB, if possible, to store patient data, contingency plans and other critical medical information.
- For backup medical devices, hospitals should have these in a storage room for emergencies.
- Backup medical devices should only be implemented if budget and resources allow for it.
- Some backup critical backup medical devices can include life support machines, defibrillators and infusion Pumps
- This storage room should be locked when it in use to prevent theft or sabotage by an attacker.
- Hospitals should also have radios for staff communication during power outages.
- This is important because staff needs to coordinate and support patients during power outages as it can mean the difference between life or death.
- Hospitals should also be built with multiple generators separated between main and backup generators.
- These are important to prevent power outages as they can cause patient deaths due medical devices failing.
- Hospitals should also have contingency plans for situations like fires, evacuations, lockdowns.
- You can find specific structures for contingency planning in my security architecture on my security repo.

Hospital Backup System Trade-offs

- **This hospital backup system has trade-offs just like any other system I've built.**
- **I have identified 4 main trade-offs.**
- **The first trade-off is budget.**
- **This trade-off exists because some features such as the cloud options, generators and backup medical devices can be expensive for hospitals.**
- **This means that some hospitals will not be able to implement all measures in digital and physical layers.**
- **This trade-off can be managed through hospitals implementing what's needed for their threat model and within their budget.**
- **You can use my threat actor and security architecture documents for more information if needed.**
- **The second trade-off is vendor management.**
- **This trade-off exists because some hospitals must have BAA and must have legal defence with storing patient data in third-party solutions.**
- **This means that some hospitals will not be able to use options like Proton Drive which do not currently have BAA reducing redundancy of patient data.**
- **This trade-off can be managed through using private, secure and BAA-supportive cloud providers like sync.com and Tresorit.**
- **It can also be managed by using non-BAA supportive cloud providers for non-patient data purposes.**
- **The third trade-off is staff overload.**
- **This trade-off exists because hospital IT teams must manage multiple security features and backup systems which can be exhausting and stressful.**
- **This can lead to misconfigurations and weak redundancy as IT teams do not have the energy to build effective systems.**
- **This trade-off can be managed through automation, slow phasing and splitting workloads with legal compliance (BAA).**
- **The fourth and final trade-off is third-part trust for patient data**
- **This trade-off exists because hospitals must trust the provider with data security and integrity.**
- **This means that if the provider were to fail or be compromised then patient data could be accessed or lost.**
- **This trade-off can be managed through self-hosted cloud, zero-knowledge & end-to-end encrypted cloud providers and client-side encryption for the most sensitive data.**